Университетская лабораторная работа

Отчет по лабораторной работе № 3

Разработка модели угроз и модели нарушителя программной системы

Дисциплина:	Основы разработки защищенного программного обеспечения и компьютерных сетей
Вариант:	19 — Система учета транспортных средств организации
Исходная версия:	v0.2
Версия ЛР:	v0.3
Студент:	Мостовая Полина Андреевна
Группа:	ИУСбд-02-23

2026

Содержание

1 Цель работы 2

2 Исходное состояние и предметная область 2

3 Область анализа, допущения и ограничения 3

4 Модель нарушителя 4

5 Диаграмма потоков данных 5
5.1 Границы доверия 7
5.2 Точки входа 8

6 Сценарии угроз по STRIDE 8

7 Оценка и обработка рисков 10
7.1 Три приоритетных риска 12

8 Требования и приемочные сценарии 12

9 Таблица прослеживаемости 13

10 Проверка реализации и Git 15

11 Ответы на контрольные вопросы 16

12 Вывод 17

Список использованных источников 18

1. Цель работы

Цель работы — освоить выявление угроз программной системе, описание возможностей и ограничений нарушителей, построение диаграммы потоков данных, предварительную оценку рисков и обоснование защитных мер. Модель связывается с конкретными функциями и активами системы учета транспорта.

2. Исходное состояние и предметная область

Сквозной проект — система учета транспортных средств организации. Она предназначена для ведения реестра автопарка, закрепления транспорта за водителями, планирования поездок, учета пробега и контроля технического состояния.

Исходный лабораторный тег `v0.2` указывает на commit `4026dd7`. Документация предыдущего этапа включает активы AS-1–AS-10, роли и предварительную матрицу доступа, требования SEC-1–SEC-13 и приемочные сценарии AT-1–AT-6.

Фактически приложение загружает настройки из переменных окружения и файла `.env`, проверяет имя приложения, режим работы и минимальную длину `APP_SECRET_KEY`, затем печатает стартовое сообщение без значения секрета. Сетевого интерфейса, аутентификации и авторизации, базы данных, учета транспортных средств и поездок и журнала аудита нет. Тестовый набор содержит три теста стартового сообщения.

Проектируемое состояние включает пользовательский интерфейс, процессы аутентификации и учета, базу данных учетных записей и транспортных данных, отчетность и журналирование. Эти компоненты помечены как запланированные. Сценарий угрозы не доказывает наличие уязвимости, а требование не доказывает, что контроль уже работает.

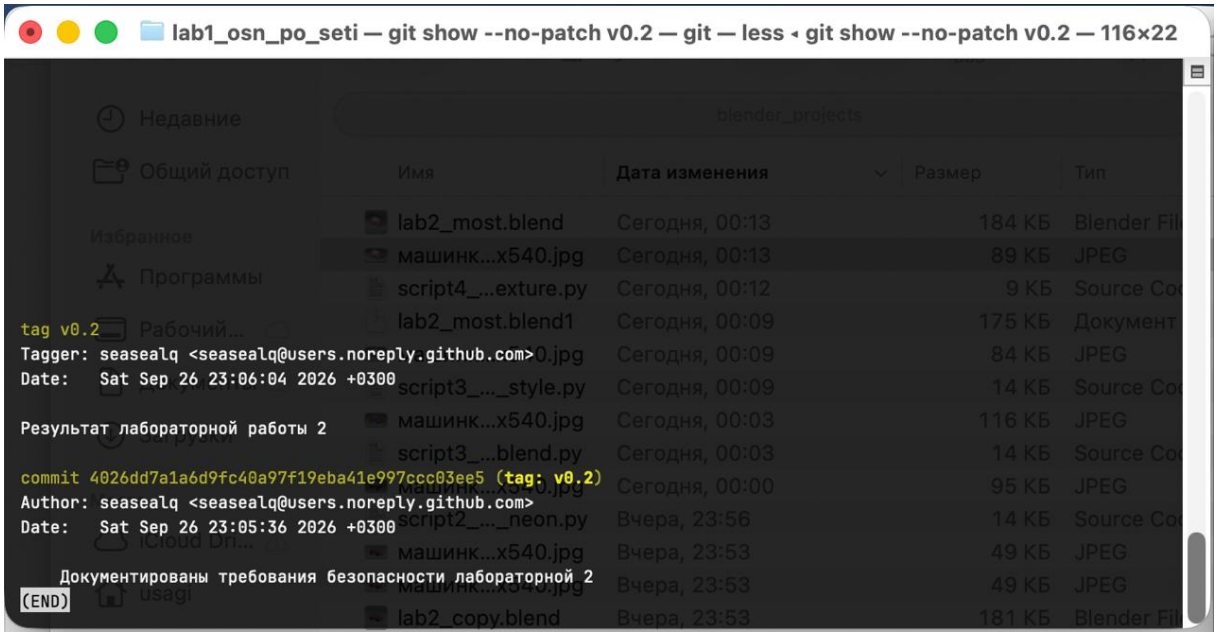


Рис. 1: Просмотр исходной метки v0.2 и commit.

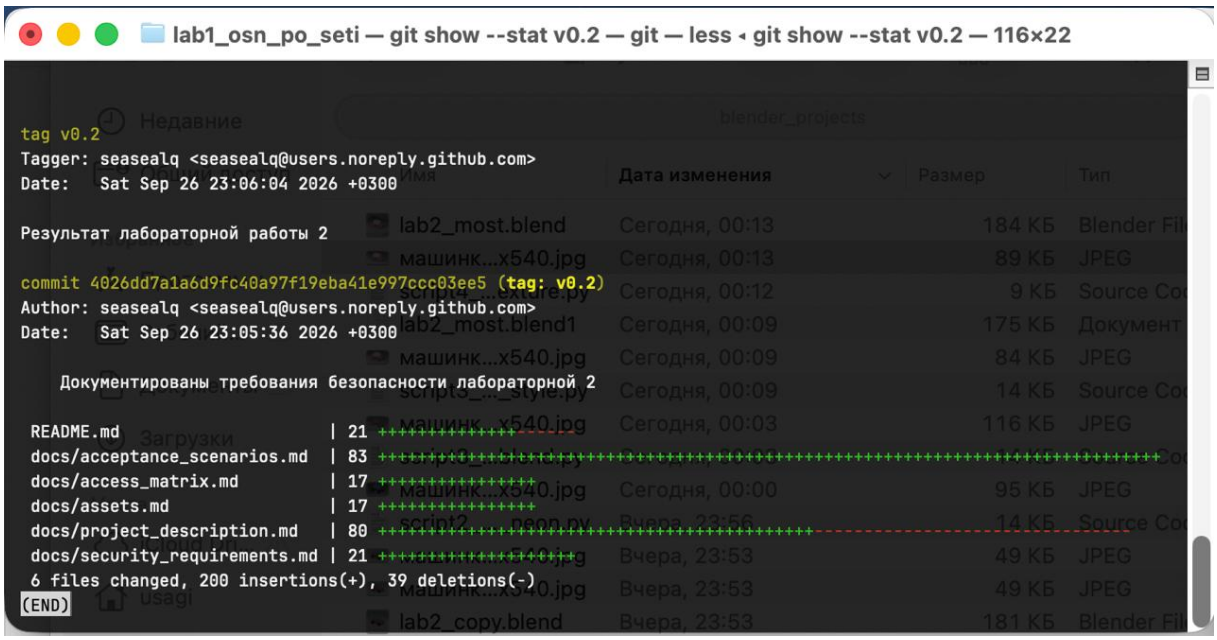


Рис. 2: Состав документации лабораторной работы № 2.

3. Область анализа, допущения и ограничения

Рассматриваются вход, просмотр и ведение карточек ТС, назначения, поездки, отчеты, техническое состояние, управление доступом и аудит. Внешняя кадровая система, бухгалтерия, телематика, фактическое местоположение и физическое управление транспортом исключены. Для учебных проверок используются искусственные данные.

Таблица 1: Допущения модели

ID	Допущение	Если оно неверно	Статус защиты
ASM-01	Клиент обращается к приложению; прямой доступ рабочего места к БД не предоставляется	Нужен отдельный анализ сетевого доступа к СУБД	Требует проверки; интерфейса нет
ASM-02	Клиентские запросы и переданные идентификаторы недоверенные	Возрастет риск подмены владельца или назначения	Серверная проверка запланирована
ASM-03	Учетная запись приложения к БД имеет только необходимые права	Компрометация процесса затронет больше данных	Требует проверки после выбора СУБД
ASM-04	Учебная среда использует искусственные данные	Реальные данные требуют пересмотра последствий и доступа	Искусственные примеры применяются; эксплуатация не подтверждена

ID	Допущение	Если оно неверно	Статус защиты
ASM-05	Журнал логически отделен от учетных данных, доступ ограничен	Изменение данных может скрыть историю действий	Требует проверки; физическое разделение не определено
ASM-06	Изменения назначения, состояния ТС и ролей связаны с субъектом и результатом	Сложнее расследовать фиктивную выдачу/возврат и смену ролей	Требование сформулировано; механизм не реализован

Модель является проектным анализом, а не тестом на проникновение. Компрометация ОС, физическая безопасность автомобилей и правовые режимы реальных персональных данных не исследуются.

4. Модель нарушителя

Таблица 2: Типы нарушителей и ограничения

ID	Тип, исходный доступ	Возможности и цель	Отсутствующие права и ограничения
N-01	Внешнее лицо без учетной записи; публичного интерфейса сейчас нет	Может посылать запросы к будущей форме входа; цель — получить учетный доступ или нарушить доступность	Нет учетной записи, сервера и БД; планируются аутентификация, лимиты и запрет прямого доступа к БД
N-02	Водитель с собственной учетной записью, если вход реализован	Меняет параметры своих запросов; может попытаться прочитать чужую поездку или подменить отчет	Нет прав диспетчера, администратора и ОС; серверная проверка записи запланирована
N-03	Диспетчер с прикладной учетной записью	Ведет карточки автопарка и назначения; может неправомерно изменить учетную историю	Не управляет ролями, ОС или СУБД; разделение полномочий и аудит проектируются
N-04	Администратор безопасности приложения	Управляет учетными записями и ролями; может пытаться скрыть действие	Нет автоматических прав ОС/БД; нужны аудит и ограничение прикладных полномочий

ID	Тип, исходный доступ	Возможности и цель	Отсутствующие права и ограничения
N-05	Администратор среды выполнения (ОС)	Имеет локальный доступ к файлам и процессу в пределах ОС	Не является автоматически администратором приложения или СУБД; разделение системных учетных записей запланировано

Администратор приложения и администратор ОС рассматриваются отдельно: у них разные полномочия и границы доступа.

5. Диаграмма потоков данных

Диаграмма показывает логические потоки проектируемой системы, а не физическую схему сети. Для читаемости на ней показаны основные направления; потоки F1–F17 описаны после рисунка.

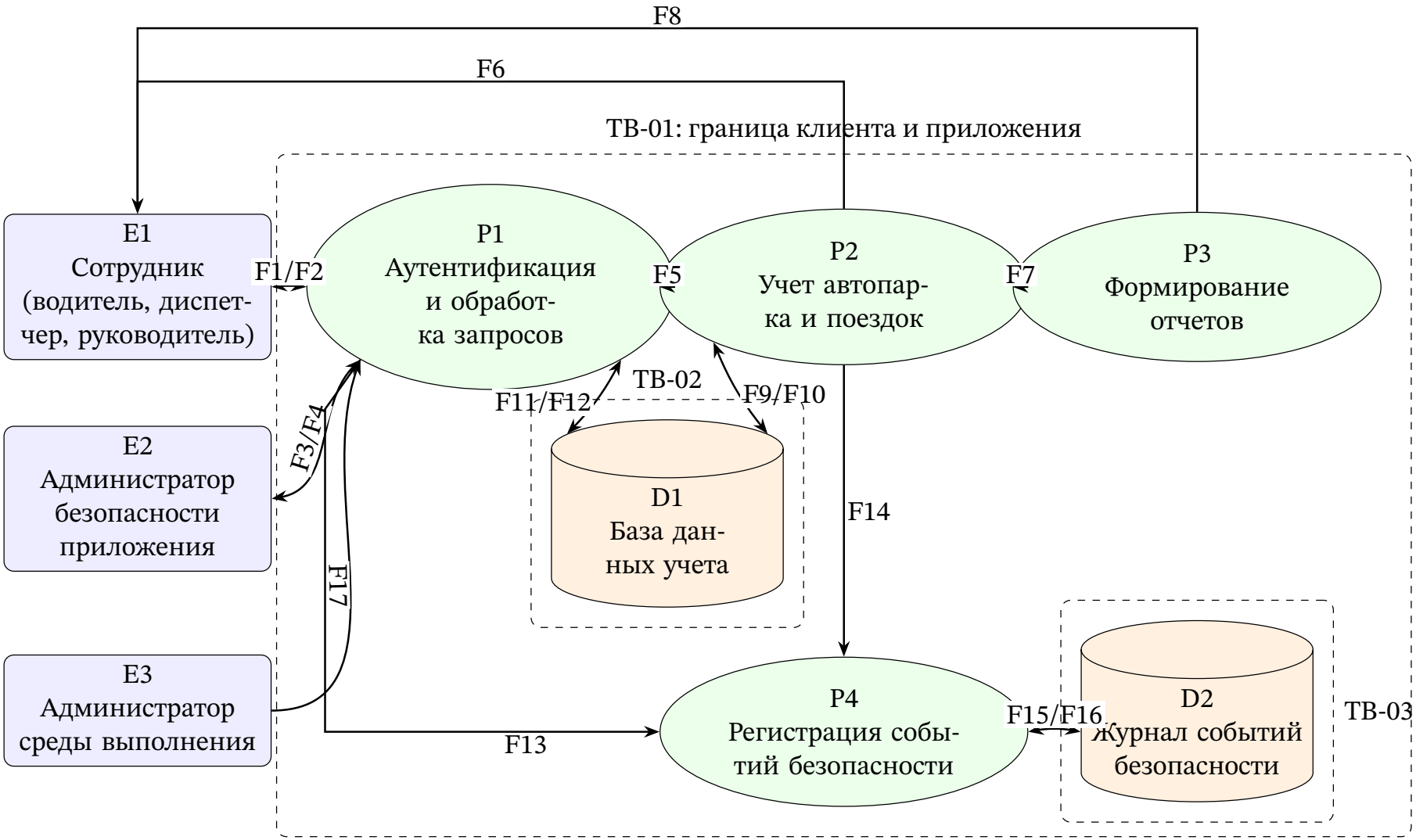


Рис. 3: DFD проектируемой системы учета транспортных средств.

Таблица 3: Элементы и потоки DFD

ID	Описание и статус
E1	Сотрудник: водитель, диспетчер или руководитель; проектируемая внешняя сущность.
E2	Администратор безопасности приложения; проектируемая внешняя сущность.
E3	Администратор среды выполнения; локальная загрузка конфигурации существует, серверные полномочия не определены.
P1	Аутентификация и обработка запросов; проектируется.
P2	Учет карточек ТС, назначений, поездок и технического состояния; проектируется.
P3	Формирование отчетов; проектируется.
P4	Регистрация событий аудита; проектируется.
D1	База профилей, ролей, карточек, поездок и состояния; проектируется.
D2	Логическое хранилище событий безопасности; проектируется, физическое разделение не подтверждено.
F1	Учетные данные и пользовательский запрос от E1 к P1; проектируется.
F2	Результат входа или разрешенный ответ от P1 к E1; проектируется.
F3	Команда управления пользователем/ролью от E2 к P1; проектируется.
F4	Результат административной операции от P1 к E2; проектируется.
F5	Разрешенный запрос учетной функции от P1 к P2; проектируется.
F6	Карточка ТС, назначение, поездка или состояние от P2 к E1; проектируется.
F7	Подготовленные данные учета от P2 к P3; проектируется.
F8	Агрегированный отчет от P3 к E1; проектируется.
F9	Чтение/запись учетных данных от P2 к D1; проектируется.
F10	Найденные записи от D1 к P2; проектируется.
F11	Учетные данные и роли от P1 к D1; проектируется.
F12	Результат проверки учетной записи от D1 к P1; проектируется.
F13	Событие входа/отказа от P1 к P4; проектируется.
F14	Событие изменения учета от P2 к P4; проектируется.
F15	Запись аудита от P4 к D2; проектируется.
F16	События для разрешенного просмотра от D2 к P4; проектируется.
F17	Конфигурация от E3 к P1; локальная загрузка реализована, серверная связь проектируется.

5.1. Границы доверия

- TB-01 — клиент/приложение. F1–F6 и F8. Проверяются подлинность пользователя, роль, право на конкретный объект, формат и размер полей, минимизация ответа.

- ТВ-02 — приложение/БД. F9–F12. Проверяются минимальные права учетной записи БД, безопасные параметризованные запросы и запрет прямого доступа клиентов.
- ТВ-03 — приложение/аудит. F13–F16. Проверяются источник и формат события, права чтения/изменения, объем хранения и реакция на заполнение.

Граница доверия может находиться между процессами или учетными записями одного сервера: она определяется полномочиями и проверками, а не только сетевой топологией.

5.2. Точки входа

Таблица 4: Точки входа проектируемой системы

Точка	Данные и источник	Проверки и состояние
Форма входа	Идентификатор и пароль; N-01/сотрудник	Проверка учетной записи, ограничение попыток, безопасный ответ; проектируется.
Чтение карточки/поездки	ID записи; водитель/диспетчер	Право на конкретную запись и минимизация ответа; проектируется.
Изменение карточки ТС	Поля и статус; диспетчер	Формат, допустимые поля/переходы и роль; проектируется.
Назначение, выдача/возврат	ID ТС, водителя, поездки, даты	Существование объектов, отсутствие конфликта, история; проектируется.
Отчет о поездке	Пробег, ID поездки, неисправность; водитель	Принадлежность, диапазон, формат/размер; проектируется.
Управление ролями	Пользователь и новая роль; N-04	Полномочие исполнителя и аудит прежнего/нового значения; проектируется.
Запрос отчета	Период и выборка; диспетчер/руководитель	Роль и агрегация без выдачи маршрутов; проектируется.
Конфигурация	APP_NAME, APP_ENV, APP_SECRET_KEY; среда запуска	Допустимые настройки и невывод секрета; частично реализовано для локального запуска.
Событие аудита	Субъект, действие, объект, время, результат; P1/P2	Источник, схема, объем и целостность; проектируется.

6. Сценарии угроз по STRIDE

Состояние «проектное предположение» относится к будущей системе и не означает найденную уязвимость.

Таблица 5: Сводный перечень сценариев угроз

ID	Категория	Сценарий, нарушитель, актив	Связи и статус
TH-01	S — подмена	N-01 при отсутствии ограничения попыток подбирает учетные данные сотрудника и действует от его имени; AS-1, AS-2.	P1/D1, F1/F11–F12, TB-01/02; SEC-1/14; проектное предположение.
TH-02	S — подмена	N-02 использует чужой действующий сеанс при недостаточных правилах отзыва; действия приписываются другому водителю; AS-1, AS-5.	P1, F2/F5, TB-01; SEC-1/14; проектное предположение.
TH-03	T — изменение	N-03 меняет ответственного или фиксирует фиктивную выдачу/возврат без проверки перехода; история поездок и ответственности недостоверна; AS-2, AS-5.	P2/D1, F5/F6/F9, TB-01/02; SEC-2/5/15; проектное предположение.
TH-04	T — изменение	N-03 меняет карточку ТС/состояние обслуживания при недостаточной валидации; запись требует исправления; AS-4, AS-6.	P2/D1, F5/F9/F10, TB-01/02; SEC-2/4/7; проектное предположение.
TH-05	T — изменение	N-02 подменяет пробег или ID поездки без серверной проверки принадлежности; отчет искажает учет; AS-5.	P2/D1, F1/F5/F6/F9, TB-01/02; SEC-2/6; проектное предположение.
TH-06	E — повышение прав	N-02 меняет запрос роли при проверке только в интерфейсе и получает функции диспетчера/администратора; AS-2.	P1/D1, F3/F4/F11/F12, TB-01/02; SEC-2/14; проектное предположение.
TH-07	R — отрицание	N-04 меняет роль, затем оспаривает действие при отсутствии записи исполнителя и прежнего/нового значения; AS-2, AS-7.	P1/P4/D2, F3/F4/F13/F15, TB-01/03; SEC-7/16; проектное предположение.
TH-08	I — раскрытие	N-02 запрашивает чужой ID поездки без проверки прав на объект и получает маршрут/назначение; AS-5, AS-8.	P1–P3/D1, F1/F2/F5–F10, TB-01/02; SEC-2/3; проектное предположение.
TH-09	I — раскрытие	N-05 или читатель диагностики получает APP_SECRET_KEY, если сообщение об ошибке выводит конфигурацию; AS-3.	P1, F17/F1/F2, TB-01; SEC-9/10; требует проверки, утечка не подтверждена.

ID	Категория	Сценарий, нарушитель, актив	Связи и статус
TH-10	D — отказ	N-01 посылает чрезмерно крупные/частые запросы без лимитов, что нарушает доступность функций; AS-10.	P1/P2, F1/F5, TB-01; SEC-18; проектное предположение.
TH-11	D — отказ	N-03/N-05 создает большой поток событий или использует отсутствие политики хранения, заполняя D2; AS-7, AS-10.	P4/D2, F13–F15, TB-03; SEC-7/16; проектное предположение.
TH-12	E/T	N-05 использует избыточные права процесса к БД после компрометации и меняет учетные записи/историю; AS-4, AS-5, AS-7.	P2/D1, F9/F10, TB-02; SEC-2/17; проектное предположение.

Покрытие категорий: S — TH-01/02; T — TH-03/04/05/12; R — TH-07; I — TH-08/09; D — TH-10/11; E — TH-06/12. STRIDE классифицирует сценарии, но не оценивает риск [3, 2].

7. Оценка и обработка рисков

Использована учебная шкала методички [1]: L=1 — низкая, L=2 — средняя, L=3 — высокая вероятность; S=1 — незначительные, S=2 — существенные, S=3 — критические последствия. Оценка рисков рассматривается как отдельный этап анализа угроз, а не как следствие одной только классификации STRIDE [4]. Балл $R = L \times S$. Приоритеты: 1–2 низкий, 3–4 средний, 6–9 высокий. Баллы являются экспертным учебным ранжированием, а не процентами вероятности или денежной оценкой. Запланированные меры не учитываются как действующие.

Таблица 6: Реестр оценок и решений

ID	L и обоснование	S и обоснование	R	Приоритет	Обработка / ответственный / срок
RS-01	3: будущая форма доступна клиенту, повторы просты без лимита.	2: доступ ограничен правами одной роли; повышение роли отдельно моделируется.	6	Высокий	Снизить; разработчик входа; v0.4.
RS-02	1: нужен чужой действующий сеанс/доступ к устройству.	2: затронуты действия в пределах прав водителя.	2	Низкий	Снизить отзывом сеанса; разработчик входа; v0.4.
RS-03	2: нужны диспетчерский доступ и отсутствие серверной проверки перехода.	2: одна неверная запись требует сверки; система не выдает ключи и не управляет ТС физически.	4	Средний	Снизить проверкой перехода и историей; учет поездок; v0.4.

ID	L и обоснование	S и обоснование	R	Приоритет	Обработка / ответственный / срок
RS-04	2: необходим диспетчерский доступ и недостаточная валидация.	2: одна карточка требует сверки; приложение не устанавливает физический допуск ТС.	4	Средний	Снизить проверкой полей/статусов; реестр ТС; v0.4.
RS-05	2: штатный отчет плюс отсутствие серверной проверки назначения.	2: отдельное значение пробега можно сверить и исправить.	4	Средний	Снизить проверкой поездки и диапазона; учет поездок; v0.4.
RS-06	2: у нарушителя есть обычная учетная запись; требуется ошибка авторизации.	3: повышение прав открывает несколько учетных функций и активов.	6	Высокий	Снизить проверкой роли на сервере; разработчик авторизации; v0.4.
RS-07	1: требуется привилегированный администратор приложения.	3: без авторства невозможно надежно расследовать смену прав.	3	Средний	Снизить аудитом изменений; администрирование; v0.4.
RS-08	3: подстановка ID проста для пользователя с доступом к чтению.	3: чужой маршрут связан с сотрудником и служебной деятельностью; раскрытие критично для AS-5.	9	Высокий	Снизить проверкой назначения до чтения; разработчик API; v0.4.
RS-09	1: штатное сообщение не выводит секрет; нужен диагностический путь с его раскрытием.	2: влияние на будущую защиту возможно, применение ключа сейчас не подтверждено.	2	Низкий	Принять под контролем SEC-9; разработчик конфигурации; пересмотр v0.4.
RS-10	2: повторы доступны при публикации, но требуется отсутствие лимитов и достаточная нагрузка.	2: возможен временный отказ части функций.	4	Средний	Снизить лимитами/наблюдением; интерфейс и оператор; v0.4.
RS-11	1: требуется поток событий или длительное отсутствие хранения/очистки.	2: возможно потерять аудит или место, D1 напрямую не меняется.	2	Низкий	Снизить квотой/предупреждением; журналирование; параметры стенда v0.4.
RS-12	1: нужен доступ к процессу и избыточная учетная запись БД.	3: при компрометации процесса возможна массовая правка учетных данных/истории.	3	Средний	Снизить минимальными правами БД; развертывание; v0.4.

Неопределенность оценок связана с тем, что API, СУБД, развертывание и политика хранения пока не выбраны. L не повышался только из-за отсутствия данных. При равных

R сценарии различаются активами и последствиями: например, RS-03 и RS-04 требуют сверки учетной истории, тогда как RS-10 касается доступности.

7.1. Три приоритетных риска

- RS-01 / TH-01. Основная мера — серверное ограничение неуспешных попыток и создание сеанса только после проверки учетной записи. Дополнительные меры — безопасно одинаковый ответ, аудит отказов и отзыв сеанса. SEC-1/SEC-14; проверка AT-10; план v0.4. Прогноз: $L_p = 1$, $S_p = 2$, $R_p = 2$. Мера снижает вероятность, не последствия.
- RS-06 / TH-06. Основная мера — серверная проверка роли для каждого запроса. Дополнительно — запрет неописанных операций и аудит смены роли. SEC-2/SEC-14; AT-8; план v0.4. Прогноз: $L_p = 1$, $S_p = 3$, $R_p = 3$. Снижается вероятность, последствия успешного обхода остаются критическими.
- RS-08 / TH-08. Основная мера — проверка сервером назначения конкретной поездки до чтения. Дополнительно — минимизация полей ответа и безопасный отказ. SEC-2/SEC-3; AT-9; план v0.4. Прогноз: $L_p = 1$, $S_p = 3$, $R_p = 3$. Снижается вероятность; тяжесть раскрытия не понижается.

Все три меры запланированы; снижение риска не подтверждено до реализации и успешной проверки.

8. Требования и приемочные сценарии

SEC-1–SEC-13 сохранены без перенумерации и изменения смысла. Добавлены требования SEC-14–SEC-18:

- SEC-14 — серверная проверка пользователя/полномочий, сеансы и ограничение попыток входа;
- SEC-15 — допустимые переходы назначения, выдачи/возврата и история прежнего/нового ответственного;
- SEC-16 — права и объем журнала, политика хранения и реакция на заполнение;
- SEC-17 — минимальные права учетной записи приложения к БД;
- SEC-18 — ограничения размера и частоты запросов.

Числовые лимиты для журнала и сетевого интерфейса не задавались до выбора стенда и профиля эксплуатации.

Существующие AT-1–AT-6 сохранены. Добавлены запланированные проверки AT-7–AT-18: назначение и история; смена роли; чтение чужого маршрута; попытки входа; отзыв сеанса; валидация карточки ТС; проверка отчета; аудит роли; секрет в ошибках; лимиты запроса; заполнение журнала; права БД. Для приоритетных рисков используются AT-10, AT-8 и AT-9 соответственно. Все новые сценарии запланированы, не выполнены; нагрузочное воздействие в этой работе не проводилось.

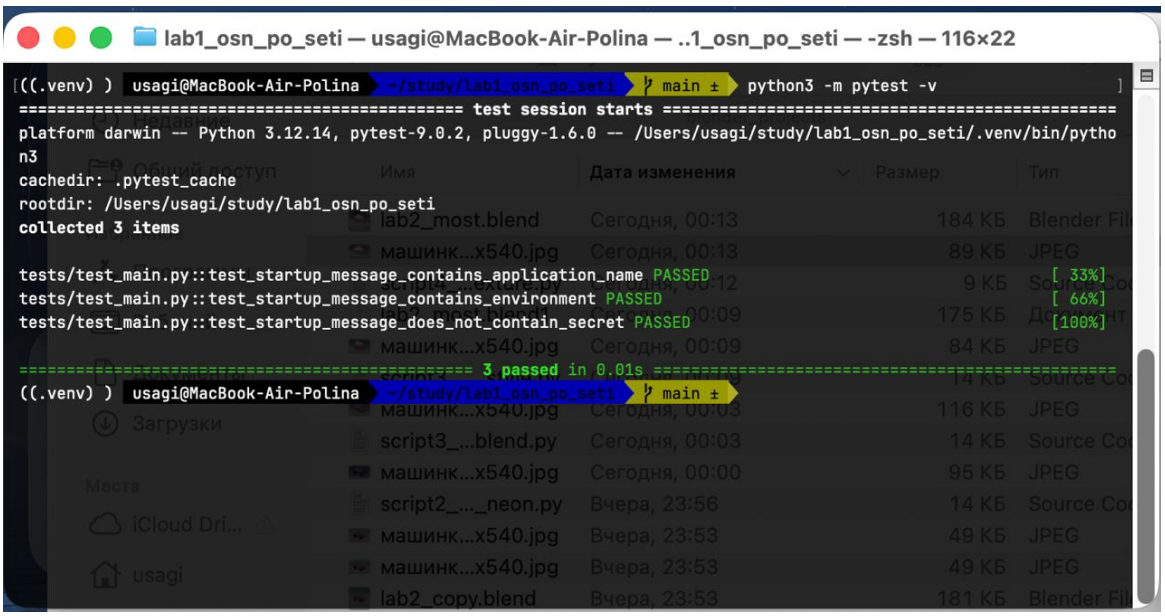
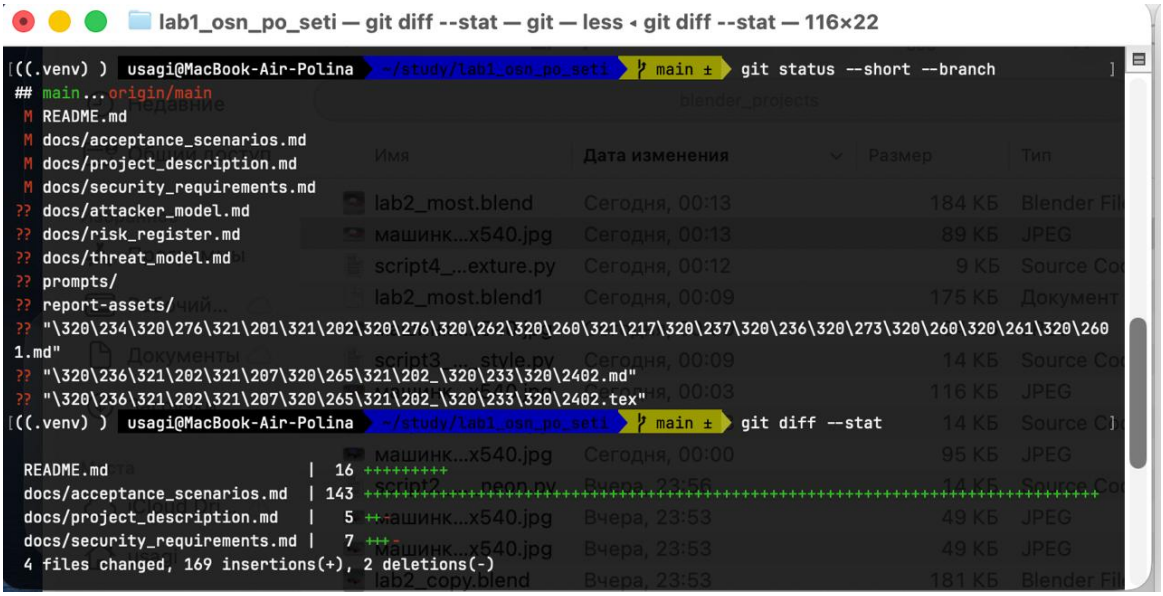


Рис. 4: Вывод трех существующих тестов прототипа.

9. Таблица прослеживаемости

Таблица 7: Прослеживаемость AS → N → TH → RS → SEC → AT

Актив	Наруши-тель	Угроза	Риск	Требование	Проверка
AS-1, AS-2	N-01	TH-01	RS-01	SEC-1, SEC-14	AT-10
AS-1, AS-5	N-02	TH-02	RS-02	SEC-1, SEC-14	AT-11
AS-2, AS-5, AS-7	N-03	TH-03	RS-03	SEC-5, SEC-15	AT-7
AS-4, AS-6	N-03	TH-04	RS-04	SEC-4, SEC-7	AT-12
AS-5	N-02	TH-05	RS-05	SEC-6	AT-13
AS-2	N-02	TH-06	RS-06	SEC-2, SEC-14	AT-8
AS-2, AS-7	N-04	TH-07	RS-07	SEC-7, SEC-16	AT-14
AS-5	N-02	TH-08	RS-08	SEC-2, SEC-3	AT-9
AS-3	N-05	TH-09	RS-09	SEC-9, SEC-10	AT-15
AS-10	N-01	TH-10	RS-10	SEC-18	AT-16
AS-7, AS-10	N-03, N-05	TH-11	RS-11	SEC-7, SEC-16	AT-17
AS-4, AS-5, AS-7	N-05	TH-12	RS-12	SEC-17	AT-18


lab1_osn_po_seti — git diff --stat — git — less ◂ git diff --stat — 116×22
((.venv)) usagi@MacBook-Air-Polina ~/study/lab1_osn_po_seti main ± git status --short --branch
main...origin/main
M README.md
M docs/acceptance_scenarios.md
M docs/project_description.md
M docs/security_requirements.md
?? docs/attacker_model.md
?? docs/risk_register.md
?? docs/threat_model.md
?? prompts/
?? report-assets/
?? "\320\234\320\276\321\201\321\202\320\276\320\262\320\260\321\217\320\237\320\236\320\273\320\260\320\261\320\260
1.md"
?? "\320\236\321\202\321\207\320\265\321\202_\320\233\320\2402.md"
?? "\320\236\321\202\321\207\320\265\321\202_\320\233\320\2402.tex"
((.venv)) usagi@MacBook-Air-Polina ~/study/lab1_osn_po_seti main ± git diff --stat
README.md | 16 ++++++++
docs/acceptance_scenarios.md | 143 ++++++++

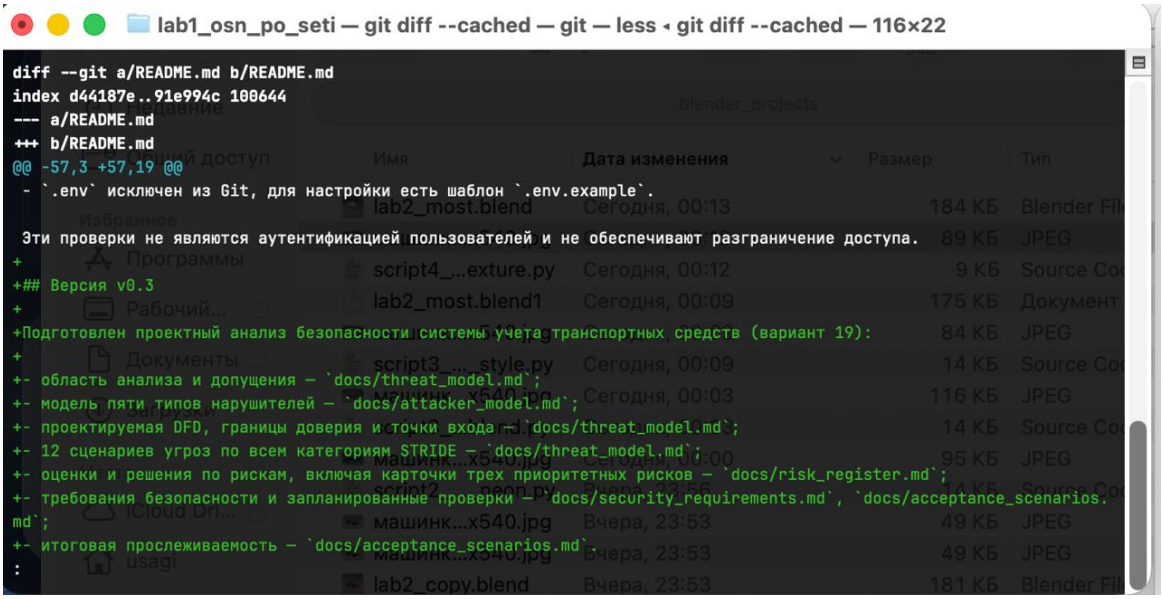


Рис. 7: Раздел v0.3 в README.

10. Проверка реализации и Git

Команда `.venv/bin/python -m pytest -v` завершилась результатом 3 passed на Python 3.12.14. Тесты проверяют только стартовое сообщение и отсутствие секрета в нем; учетные функции, роли и аудит ими не проверяются.

В истории имеется commit `9c9007e` с результатами ЛР №3 и аннотированный тег `v0.3`. На предоставленном снимке конечного состояния локальная ветка показана впереди `origin/main` на один commit; снимок сделан до отправки. Во время подготовки отчета commit `9c9007e` успешно отправлен в `origin/main` командой `git push origin main`. Тег v0.3 этой командой отдельно не отправлялся.

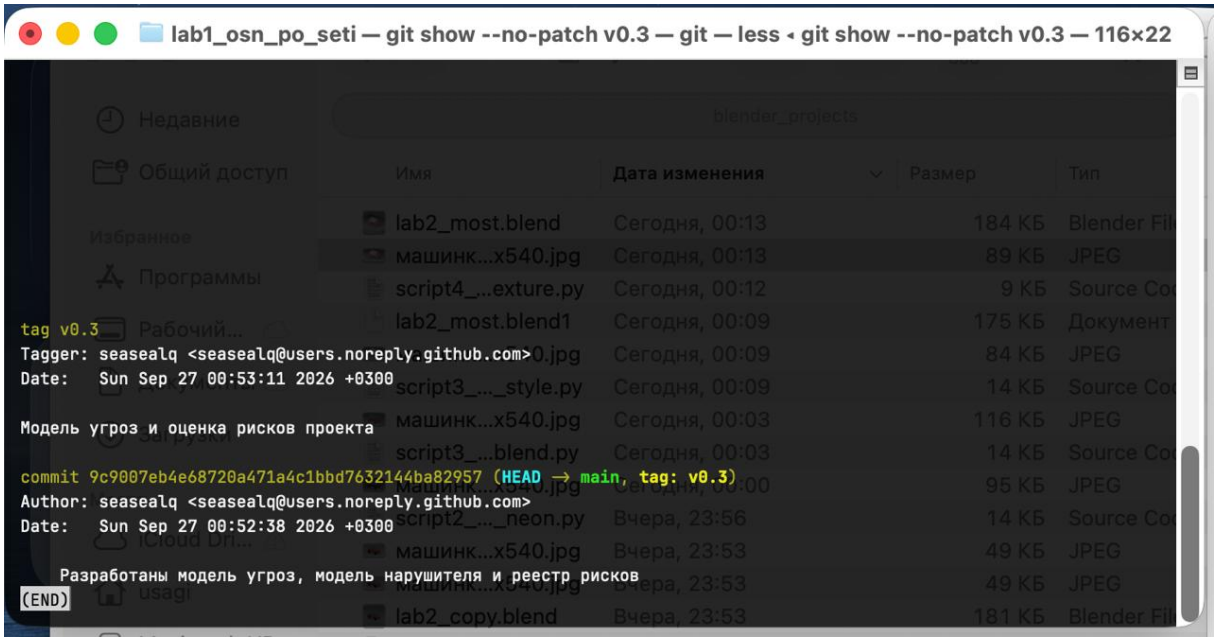


Рис. 8: Просмотр тега v0.3 и commit.

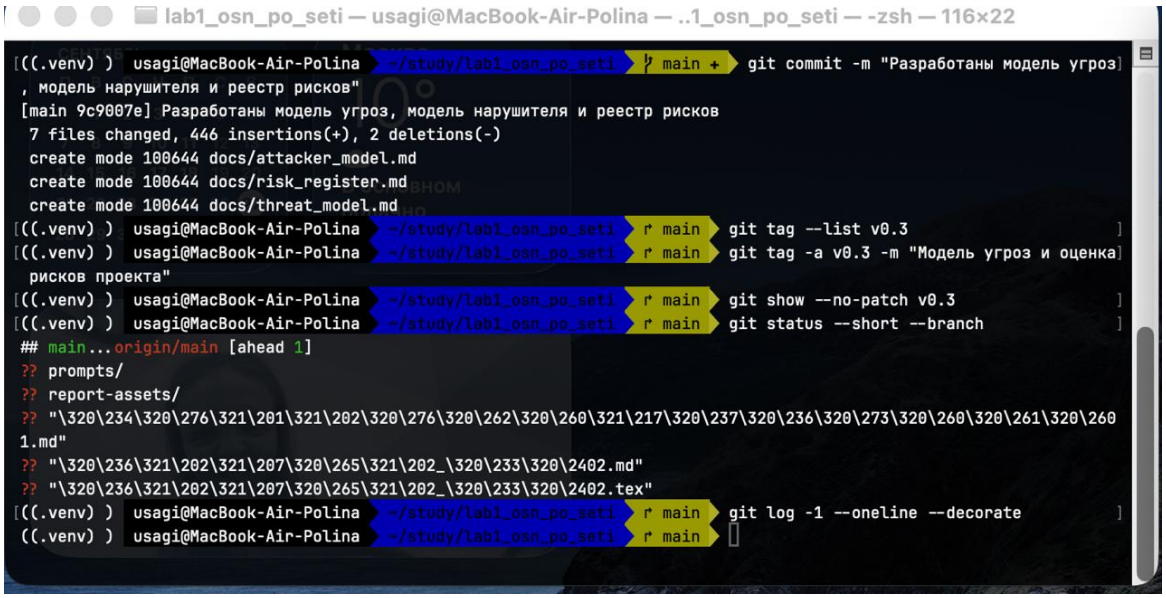


Рис. 9: Локальные commit, тег и статус до push.

11. Ответы на контрольные вопросы

1. Чем угроза отличается от уязвимости? Угроза — возможность нарушить защищаемое свойство; уязвимость — недостаток реализации, архитектуры, конфигурации или процесса, помогающий угрозе.
2. Какие сведения нужны для сценария угрозы? Нарушитель, исходный доступ, условие/недостаток, действие, затронутые элементы и активы, последствия и способы проверки мер.
3. Почему зарегистрированный пользователь может быть нарушителем? Он может использовать легитимный ограниченный доступ, чтобы попытаться выйти за свои полномочия, например запросить чужую поездку.
4. Зачем указывать ограничения нарушителя? Чтобы не приписывать ему несуществующие права и не завышать сценарий.
5. Чем администратор приложения отличается от администратора ОС? Первый управляет ролями внутри приложения, второй — ОС и процессами; полномочия не переходят автоматически.
6. Какие элементы включает DFD? Внешние сущности, процессы, хранилища, направленные потоки данных и границы доверия.
7. Что обозначает граница доверия? Переход между областями с разными полномочиями или условиями доверия, на котором нужны проверки.
8. Почему граница может быть внутри одного сервера? Процессы/учетные записи одного сервера могут иметь разные полномочия.
9. Чем DFD отличается от схемы физической сети? DFD показывает перемещение данных и логические компоненты; схема сети — узлы и соединения развертывания.
10. Какие категории включает STRIDE? Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.
11. Почему STRIDE не заменяет оценку риска? Категория не задает вероятность и последствия сценария.
12. Может ли сценарий иметь несколько категорий? Да, если действие обоснованно затрагивает несколько свойств; в реестре указываются основная и дополнительная.
13. Почему требование не доказывает устранение угрозы? Требование описывает жела-

емое поведение; нужны реализация и проверка.

14. Как связаны значимость актива и последствия? Значимость — контекст ценности; S оценивается для конкретного сценария и не переносится автоматически из Ci/Ii/Ai.
15. Ограничения формулы R=L×S? Это грубая порядковая шкала, не процент и не стоимость; произведение не отражает всю неопределенность.
16. Почему одинаковые баллы могут требовать разных решений? Различаются активы, условия, последствия, восстановление и доступные меры.
17. Какие способы обработки риска существуют? Снизить, избежать, передать/разделить либо принять с контролем и пересмотром.
18. Чем прогноз остаточного риска отличается от подтвержденного? Прогноз предполагает будущую эффективность меры; подтверждение требует ее реализации и проверки.
19. Как модель влияет на требования и тесты? Сценарии выявляют нужные проверяемые требования, а тесты подтверждают их критерии и трассируются к угрозам.
20. Когда пересматривать модель угроз? При изменении функций, архитектуры, потоков, хранилищ, интерфейсов, ролей, развертывания, зависимостей или данных, а также после новых результатов проверок.

12. Вывод

Для проектируемой системы учета транспорта определены участники, процессы, хранилища, потоки и границы доверия. На этой основе описаны возможности нарушителей и 12 сценариев STRIDE, связанные с учетными записями, карточками ТС, назначениями, поездками, отчетами и журналом. Для сценариев оценены вероятность и последствия по шкале методички, выбраны способы обработки, а требования связаны с проверками и таблицей прослеживаемости. Для трех приоритетных рисков определены меры и прогнозы остаточного риска. Функции и механизмы пока не реализованы, поэтому проверки остаются плановыми, а модель не доказывает безопасность работающей системы. Результаты служат основанием для дальнейшего проектирования защищенной архитектуры.

Список использованных источников

[1] Методические указания «Лабораторная работа № 3. Разработка модели угроз и модели нарушителя программной системы».

[2] OWASP Foundation. Threat Modeling Cheat Sheet [Электронный ресурс]. URL: https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html (дата обращения: 15.10.2026).

[3] Microsoft. Microsoft Threat Modeling Tool threats: STRIDE model [Электронный ресурс]. Microsoft Learn. URL: https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats (дата обращения: 15.10.2026).

[4] Joint Task Force Transformation Initiative. Guide for Conducting Risk Assessments. NIST SP 800-30 Rev. 1. Gaithersburg: National Institute of Standards and Technology, 2012. URL: https://csrc.nist.gov/pubs/sp/800/30/r1/final (дата обращения: 15.10.2026).